

Mapeo normativo – Indicadores OWASP (M1-M15) bajo marco GQM + PRAGMATIC

Versión 1.0 – Tabla de correspondencia orientativa entre indicadores OWASP, objetivos GQM y requisitos de NIS2/ENS.

1. Notas previas

- El mapeo es orientativo y no sustituye análisis jurídico detallado.
- Se centra en la lógica de alineamiento: qué artículo o ámbito normativo se ve mejor informado por cada indicador.
- Se asume un contexto español con ENS vigente y transposición en curso de NIS2.[web:21][web:24][web:60][web:72][web:77]

2. Tabla de mapeo M1-M15 → NIS2 / ENS

Indicador	Objetivo GQM (resumen)	Principales dominios OWASP	Ámbitos NIS2 relevantes (alto nivel)	Ámbitos ENS relevantes (alto nivel)	Comentario de uso regulatorio
M1 – Densidad de vulnerabilidades OWASP Top 10	Cuantificar exposición estructural a vulnerabilidades OWASP Top 10:2025 en sistemas españoles.	Top 10:2025; Risk Rating	Gestión de riesgos de ciberseguridad; identificación de activos y vulnerabilidades; priorización sectorial.	Análisis y gestión de riesgos; inventario de activos; protección de sistemas.	Informa evaluaciones de riesgo macro y sectoriales; apoya la proporcionalidad de medidas técnicas.
M2 – % activos críticos sin vulnerabilidades A01-A03	Evaluar robustez de activos críticos frente a fallos de acceso, configuración y cadena de suministro.	Top 10:2025 (A01-A03); ASVS capítulos de control de acceso y configuración	Medidas técnicas proporcionales a riesgo; seguridad de red y sistemas; seguridad de la cadena de suministro.	Medidas de protección para sistemas de categoría media/alta; gestión de cambios; endurecimiento.	Indicador casi directo de cumplimiento de medidas técnicas reforzadas en servicios esenciales/importantes.
M3 – Cobertura de análisis frente a Top 10	Medir cobertura de pruebas de seguridad de aplicaciones mapeadas a Top 10:2025.	Top 10:2025; SAMM Verificación; Security Culture (métricas de testing)	Medidas técnicas de detección y prueba; obligación de pruebas periódicas.	Verificación; auditoría técnica; monitorización de seguridad.	Sirve para evidenciar diligencia en pruebas de seguridad; útil en auditorías ENS y supervisión NIS2.
M4 – MTTR de vulnerabilidades Top 10	Medir agilidad de remediación de vulnerabilidades críticas en activos críticos.	Top 10:2025; Risk Rating; SAMM Operaciones	Gestión de incidentes y tratamiento de vulnerabilidades; tiempo de reacción; continuidad.	Gestión de incidentes; continuidad del servicio; tiempos de respuesta.	Indicador operativo clave para demostrar capacidad de respuesta y resiliencia.

M5 – Score medio SAMM por función	Evaluar madurez de programas de seguridad de software (Gobernanza, Diseño, Implementación, Verificación, Operaciones).	SAMM completo	Medidas organizativas; gobierno de la seguridad; gestión de riesgos de desarrollo.	Organización de la seguridad; política y procedimientos; ciclo de vida de sistemas.	Ayuda a justificar planes de mejora estructural y a demostrar cumplimiento de “medidas organizativas adecuadas”.
M6 – % entidades con nivel ≥ 2 en “Strategy and Metrics”	Medir adopción de estrategia y métricas de seguridad de software a nivel organizativo.	SAMM – Strategy and Metrics	Gobernanza; responsabilidad de la alta dirección; supervisión periódica.	Marco organizativo, responsabilidad y supervisión; métricas y revisión.	Muestra hasta qué punto las organizaciones tratan la seguridad de software como disciplina estratégica y medible.
M7 – Pendiente de mejora SAMM (ΔSAMM)	Medir velocidad de maduración de prácticas de seguridad de software.	SAMM	Mejora continua de la gestión de riesgos; programas de refuerzo.	Mejora continua; revisión periódica de medidas.	Evidencia la progresión (o estancamiento) de la madurez; útil en planes plurianuales.
M8 – Cobertura de autoevaluaciones SAMM	Medir porcentaje de entidades que se autoevalúan con SAMM al menos cada 2 años.	SAMM; Security Culture (métricas de programa)	Gestión sistemática de riesgos en el ciclo de vida del servicio; cultura de medición.	Autoevaluación; auditorías internas; revisión de la eficacia de controles.	Indicador de “higiene de métricas”: demuestra voluntad de medir y mejorar, aunque no garantice por sí solo buena seguridad.

M9 – Distribución de niveles ASVS por criticidad ENS/NIS2	Evaluar nivel de aseguramiento técnico de aplicaciones en función de su criticidad regulatoria.	ASVS 5.0; Top 10:2025 (controles)	Medidas técnicas de protección; seguridad de aplicaciones; proporcionalidad a criticidad de servicios.	Medidas específicas para sistemas de categoría media/alta; seguridad de aplicaciones.	Conecta directamente niveles ASVS con exigencias ENS/NIS2; muy útil para establecer mínimos regulatorios sectoriales.
M10 – Densidad de requisitos ASVS cumplidos por capítulo	Identificar áreas técnicas fuertes/débiles en controles de aplicaciones.	ASVS 5.0 (capítulos técnicos)	Medidas técnicas detalladas (autenticación, control de acceso, criptografía, logging, etc.).	Seguridad por capas; controles específicos por dominio técnico.	Permite focalizar acciones de mejora en dominios técnicos concretos; apoyo en auditorías técnicas ENS.
M11 – Cobertura de pruebas vs ASVS	Medir porcentaje de requisitos ASVS cubiertos por pruebas automatizadas y manuales.	ASVS 5.0; SAMM Verificación	Medidas técnicas de prueba y verificación continua; CI/CD seguro.	Verificación; pruebas de seguridad; automatización.	Indica grado de integración de seguridad en SDLC; relevante para demostrar cumplimiento de “seguridad desde el diseño y por defecto”.
M12 – Ratio de defectos ASVS en producción	Medir deuda de seguridad que se escapa al SDLC y se manifiesta en producción.	ASVS 5.0; Top 10; SAMM Operaciones	Incidentes de seguridad; impacto en la prestación de servicios; responsabilidad ante brechas.	Gestión de incidentes; lecciones aprendidas; calidad de operación.	Métrica crítica para evidenciar eficacia real del SDLC seguro, más allá de la documentación.

M13 – Distribución de severidad OWASP en infraestructuras críticas	Caracterizar perfil de severidad de vulnerabilidades en infraestructuras críticas.	OWASP Risk Rating; Top 10	Gestión de riesgos sectoriales; priorización de supervisión; resiliencia de infraestructuras críticas.	Clasificación de sistemas y servicios críticos; gestión reforzada de seguridad.	Apoya decisiones sobre sectores y sistemas prioritarios en planes nacionales; útil para CN-CERT/INCIBE.
M14 – Riesgo medio OWASP normalizado por sector	Comparar perfiles de riesgo OWASP entre sectores regulados.	OWASP Risk Rating; Top 10	Gestión y supervisión de riesgos intersectoriales; coordinación entre autoridades competentes.	Coordinación interadministrativa; planes de seguridad sectoriales.	Base para cuadros de mando de alto nivel (Gobierno, agencias reguladoras); orienta recursos e inspecciones.
M15 – Tiempo detección técnica → decisión ejecutiva	Medir alineamiento entre detección técnica y toma de decisiones de negocio.	OWASP Risk Rating; SAMM Governance	Gobernanza; responsabilidad de la alta dirección; reporting y toma de decisiones.	Marco organizativo; comunicación de incidentes y riesgos.	Indicador de madurez de gobernanza y cumplimiento de exigencias NIS2 sobre implicación de la alta dirección.

3. Uso práctico del mapeo

- Para reguladores: ayuda a seleccionar qué indicadores exigir o recomendar como evidencias en supervisión ENS/NIS2 (por ejemplo, M2, M4, M9, M12, M15).
- Para CISOs y equipos internos: traduce métricas técnicas OWASP al idioma de cumplimiento y gobernanza, facilitando conversaciones con legales y cumplimiento.
- Para investigación y políticas públicas: ofrece un andamiaje para estudios longitudinales sobre el impacto de NIS2/ENS en la postura de seguridad y la madurez OWASP del país.